

INT304: Network Security and Protocols – Lab 2: Network Security Policies and Risk Management Comprehensive Report

Academic Module: Cybersecurity Risk and Governance

Lab Title: Network Security Policies and Risk Management

Date of Submission: October 19, 2025

Group Focus: Apex Financial Services (Hypothetical Institution)

I. Executive Summary: Establishing Our Security Foundation

Our team undertook this lab exercise to gain hands-on experience in building out a foundational network security policy and applying a practical risk assessment framework. Simply put, robust security policies aren't just bureaucratic documents; they are essential governance tools that protect a company's most valuable assets and ensure we comply with all legal requirements.

Essential Components of a Strong Security Policy:

A truly effective policy must clearly define the organization's expectations and response mechanisms. Key elements we focused on included:

1. **Purpose and Scope:** Clearly defining what the policy is meant to protect and which systems and people it applies to.
2. **User Responsibilities:** Setting clear rules for how employees should use network resources and what their accountability is.
3. **Incident Response Plan (IRP):** Detailing the step-by-step process we follow when a security incident occurs, from initial detection to recovery.
4. **Compliance:** Ensuring the organization meets all relevant laws and contractual obligations (like GDPR or PCI DSS for a financial firm).

II. Our Team's Risk Assessment Methodology (Apex Financial Services)

We selected Apex Financial Services, a mid-sized firm that handles sensitive customer Personally Identifiable Information (**PII**) and high-volume financial data, as our case study. Our assessment followed industry standard methodology to identify, analyze, and rate the most significant threats.

2.1. Critical Asset Identification

We prioritized assets based on their criticality to the company's operations and regulatory standing:

- **A-1: Customer PII and Financial Records:** This is high-value, highly sensitive data, including account numbers, transaction logs, and identity documents.

- **A-2: Core Transaction Processing Systems:** The servers, databases, and network gear that handle real-time fund transfers and market operations.
- **A-3: Proprietary Intellectual Property (IP):** Confidential assets like internal trading algorithms, security diagrams, and source code.

2.2. Threat, Vulnerability, and Impact Analysis

We analyzed common threat vectors against our identified assets:

Asset	Potential Threat	Specific Vulnerability	Potential Impact (I)	Likelihood (L)
A-1 (Customer Data)	Ransomware/Extortion	Ineffective email filtering or employees falling for phishing scams.	Catastrophic (Massive financial loss, regulatory fines)	High
A-2 (Transaction Systems)	Distributed Denial-of-Service (DDoS)	Lack of robust traffic filtering or cloud-based DDoS scrubbing services.	High (System downtime, reputational damage)	Medium
A-3 (Proprietary IP)	Insider Threat/Theft	Granting employees too much access (over-privileging) to core repositories.	High (Loss of competitive advantage)	Low

A-1 & A-2	Zero-Day Exploits	Using outdated, unpatched server applications (like Apache 2.2, which we saw in previous labs).	Catastrophic (Full system compromise , data theft)	Medium
----------------------	-------------------	---	--	--------

2.3. Determining Risk Rating and Strategy

We calculated risk using the matrix model: Risk = Likelihood $\times$ Impact. The following table summarizes our findings and initial recommendations:

Threat Scenario	Likelihood (L)	Impact (I)	Risk Rating	Treatment Strategy
Phishing/Ransomware (A-1)	High (5)	Catastrophic (5)	High (25)	Mitigation: Mandate user training and enforce Multi-Factor Authentication (MFA).
DDoS (A-2)	Medium (3)	High (4)	High (12)	Mitigation: Implement professional DDoS protection services.
Zero-Day/Unpatched Apps (A-1/A-2)	Medium (3)	Catastrophic (5)	High (15)	Mitigation: Establish a strict patch management and

				vulnerability lifecycle.
Insider Threat (A-3)	Low (2)	High (4)	Medium (8)	Prevention: Strictly enforce the Principle of Least Privilege.

III. Draft Policy Solutions: The Security Policy Elements

Based on the three major High Risk ratings, we drafted essential policy elements tailored specifically for Apex Financial Services.

3.1. Access Control Policy (ACP)

Core Mandate: All access to the network and applications must strictly follow the **Principle of Least Privilege**.

- **Authentication:** Multi-Factor Authentication (**MFA**) is required for all remote access, privileged accounts, and mission-critical logins. Passwords must comply with NIST guidance.
- **Authorization:** Employees must only be granted access to the bare minimum resources necessary to perform their jobs. Access rights will be reviewed every quarter and immediately revoked upon role changes or termination.
- **Session Management:** Remote sessions for sensitive servers will automatically time out after fifteen (15) minutes of inactivity, requiring users to re-authenticate.

3.2. Data Protection Policy (DPP)

Core Mandate: Sensitive data must be protected from unauthorized access or modification at every stage of its lifecycle.

- **Data Encryption:** All Customer PII (A-1) and proprietary IP (A-3) must be fully encrypted, both **at rest** (in the database) and **in transit** (using TLS 1.2 or higher).
- **Data Loss Prevention (DLP):** We must deploy DLP technology to monitor and block the transmission of sensitive data through unauthorized channels (e.g., personal emails or external cloud drives).
- **Data Retention:** We must strictly enforce retention schedules to ensure data is properly purged once regulatory and business requirements have been met.

3.3. Incident Response Procedures (IRP)

Core Mandate: A clear, six-stage framework will guide our response to all security incidents.

1. **Preparation:** Maintain up-to-date contact lists, tools, and runbooks *before* an incident occurs.
2. **Detection & Analysis:** Use systems like IDS/IPS (e.g., Snort) and SIEM tools for immediate threat identification.
3. **Containment:** Quickly isolate the affected systems or network segments (e.g., quarantine the compromised host) to prevent the attack from spreading.
4. **Eradication:** Find and eliminate the root cause of the incident, which includes patching vulnerabilities and cleaning infected systems.
5. **Recovery:** Restore all systems to full operational status using trusted backups and verify security integrity.
6. **Lessons Learned:** Conduct a thorough post-incident review to update our policies, procedures, and training modules.

3.4. Training and Awareness Policy (TAP)

Core Mandate: We must maintain a security-aware workforce that can recognize and report threats, which is our primary defense against phishing and ransomware.

- **Mandatory Training:** All employees must complete comprehensive security awareness training upon hiring and annually thereafter.
- **Simulated Testing:** Unannounced phishing campaigns will be run quarterly. Personnel who fail the simulations will be required to take immediate remedial training.

IV. Feedback and Reflection: Continuous Improvement

4.1. Peer Feedback and Discussion

The feedback we received from our peers was constructive and focused on making the policies truly measurable and sustainable over time:

1. **Metrics and Measurement:** Our policies need defined metrics. For example, the **Access Control Policy** should include a rule that all users with standing root access must be reviewed on a monthly basis.
2. **Policy Life Cycle:** We realized the draft was missing from a formal review mechanism. The recommendation was to mandate a **Security Policy Review Board** that meets twice a year to approve policy changes based on emerging threats.

3. **Technological Integration:** While we mentioned Snort, the feedback suggested we must more explicitly link threat intelligence (like newly detected Command and Control IPs) to automated preventative controls, such as automatic firewall updates.

4.2. Reflection on Policy Adaptability

This lab deeply reinforced the idea that security policy development is a continuous cycle, it's never a one-time project. Because technology changes and the threat landscape evolve (for example, the older Apache vulnerabilities we saw in other labs), organizations must remain agile.

Moving forward, Apex Financial Services must:

- **Regularly Review:** Stick to a defined policy review schedule (at least annually) and trigger immediate reviews when major new vulnerabilities are discovered.
- **Incorporate Threat Intelligence:** Policies should be proactively adjusted based on intelligence about zero-day exploits or evolving attack techniques, creating a live feedback loop between our operations and our governance.
- **Align with Business Needs:** Policies have to be flexible enough to handle growth, new technology (like moving to the cloud), and shifting business goals without unnecessarily creating friction for employees.